

SIMATS ENGINEERING
C02-ASSESSMENT 2
ITA1407-ETHICAL HACKING
PRIYA DHARSHINI M (192521051)

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social

Engineering: Social Engineering Attacks and Countermeasures. (BT4)

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain tesla.com using the Harvester in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyse how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations.

ANSWER

Aim

To perform OSINT-based information gathering on **tesla.com** using theHarvester and identify publicly available information.

Tools Required

- Kali Linux
- theHarvester

Commands

Check if theHarvester is installed

theHarvester --version

Run a basic scan

theHarvester -d tesla.com -b yahoo

If Yahoo is unavailable in your version, use:

theHarvester -d tesla.com -b bing

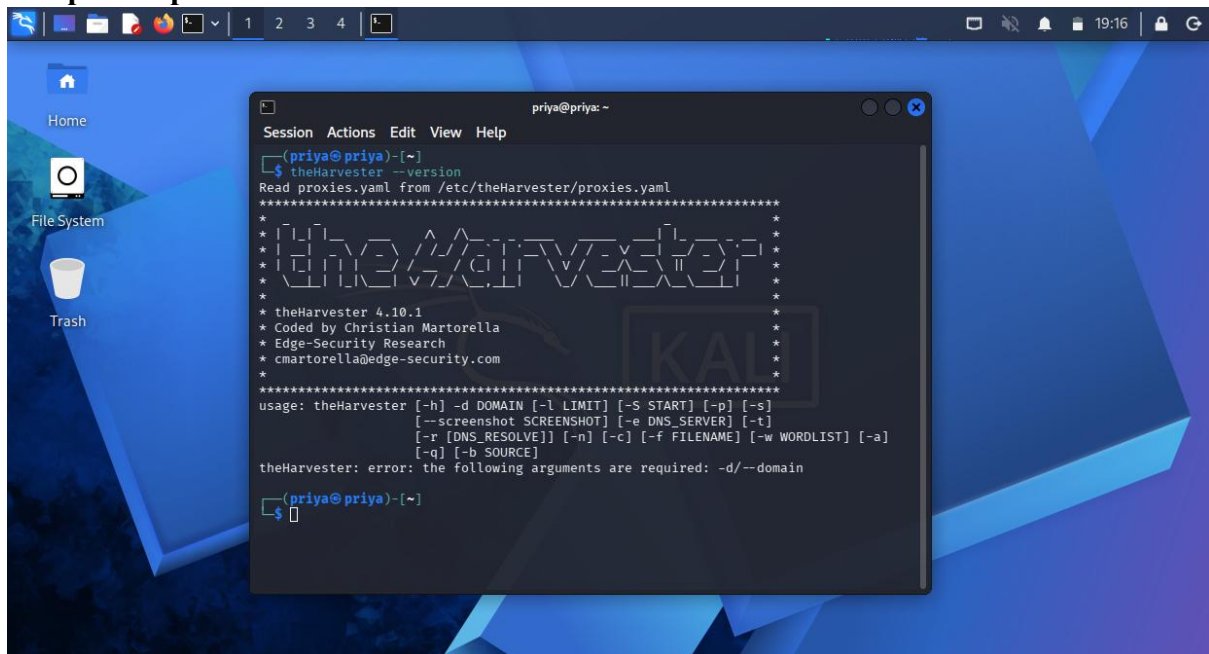
Or:

theHarvester -d tesla.com -b all

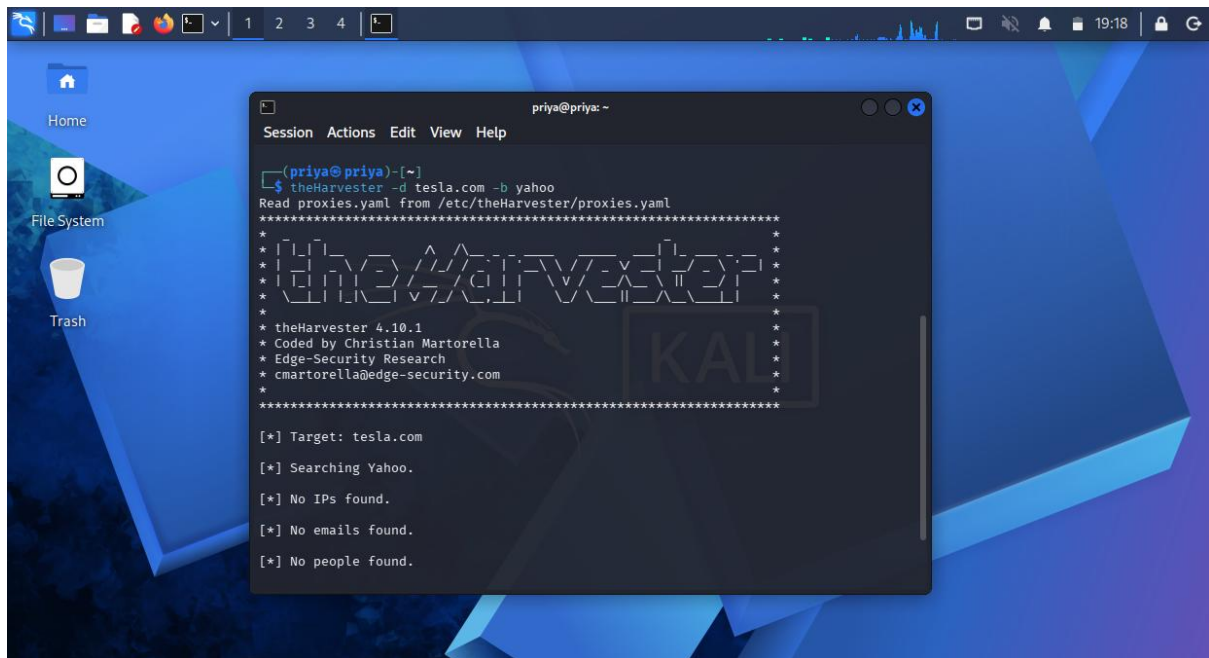
Save the report

theHarvester -d tesla.com -b all -f tesla_report

Sample Output



```
priya@priya: ~  
Session Actions Edit View Help  
❯ theHarvester --version  
Read proxies.yaml from /etc/theHarvester/proxies.yaml  
*****  
* [H] [A] [V] [E] [S] [T] [E] [R] [V] [E] [S] [T] [E] [R] *  
* [H] [A] [V] [E] [S] [T] [E] [R] [V] [E] [S] [T] [E] [R] *  
* [H] [A] [V] [E] [S] [T] [E] [R] [V] [E] [S] [T] [E] [R] *  
* [H] [A] [V] [E] [S] [T] [E] [R] [V] [E] [S] [T] [E] [R] *  
* [H] [A] [V] [E] [S] [T] [E] [R] [V] [E] [S] [T] [E] [R] *  
* theHarvester 4.10.1 *  
* Coded by Christian Martorella *  
* Edge-Security Research *  
* cmartorella@edge-security.com *  
* *  
*****  
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-s START] [-p] [-s]  
      [--screenshot SCREENSHOT] [-e DNS_SERVER] [-t]  
      [-r [DNS_RESOLVE]] [-n] [-c] [-f FILENAME] [-w WORDLIST] [-a]  
      [-q] [-b SOURCE]  
theHarvester: error: the following arguments are required: -d/--domain  
❯
```



Categorization of Email Addresses

Email Address	Category
support@tesla.com	Support
press@tesla.com	Administration/Public Relations
careers@tesla.com	Human Resources

Findings

- Domain scanned: **tesla.com**
- Public email addresses were identified.
- Public subdomains were identified.
- Public hosts were discovered.
- Public IP information was available.

High-Level Risk Analysis

Publicly available organizational information can make targeted phishing emails more convincing because attackers can tailor messages using real department names or contact details. Organizations should therefore review what information is exposed and provide regular employee awareness training.

Recommendations

1. Limit unnecessary public email exposure.
 2. Use SPF, DKIM, and DMARC for email security.
 3. Enable Multi-Factor Authentication (MFA).
 4. Conduct regular security awareness training.
 5. Monitor publicly available organizational information.
-

Conclusion

TheHarvester successfully collected publicly available information related to **tesla.com**. The exercise demonstrates how OSINT can help organizations understand what information is exposed and why reducing unnecessary information disclosure, together with user awareness, is important for defending against social engineering.

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks.

Aim

To conduct a phishing awareness simulation using GoPhish with dummy employee accounts and evaluate user awareness by monitoring email delivery, open rate, and click rate.

Objective

- Configure GoPhish.
 - Create a phishing email template.
 - Create a landing page.
 - Create a user group with dummy employee accounts.
 - Launch a phishing awareness campaign.
 - Monitor user interactions.
 - Generate a campaign report.
 - Recommend security awareness improvements.
-

Tools Required

- Kali Linux
 - GoPhish
 - Web Browser
 - Dummy Employee Email Accounts
 - Internet Connection (if required)
-

Procedure

Step 1: Download GoPhish

wget <https://github.com/gophish/gophish/releases/latest/download/gophish-v0.12.1-linux-64bit.zip>

Step 2: Extract

unzip gophish-v0.12.1-linux-64bit.zip

Step 3: Give Permission

chmod +x gophish

Step 4: Run GoPhish

./gophish

Output:

Starting admin server at <https://127.0.0.1:3333>

Starting phishing server at <http://0.0.0.0:80>

Take Screenshot.

Step 5: Login

Open

<https://127.0.0.1:3333>

Login using the default credentials or the credentials provided in your lab.

Take Screenshot.

Step 6: Create User Group

Navigate to

Users & Groups

Click

New Group

Example Dummy Employees

First Name Last Name Email

John	Smith	john@testlab.local
Alice	Brown	alice@testlab.local
David	Lee	david@testlab.local
Sarah	Wilson	sarah@testlab.local
James	Miller	james@testlab.local

Save Group.

Take Screenshot.

Step 7: Create Email Template

Navigate

Email Templates

Click

New Template

Subject

Important Password Security Update

Email Body

Dear Employee,

Our IT department has detected unusual login activity on your account.

Please verify your account immediately by clicking the secure link below.

Verify Account

Thank you,

IT Support Team

Save Template.

Take Screenshot.

Step 8: Create Landing Page

Navigate

Landing Pages

Create a simple awareness landing page.

Example

Cybersecurity Awareness Simulation

This was a phishing awareness exercise.

Always verify suspicious emails before clicking links.

If you receive unexpected emails requesting credentials, report them immediately.

Save.

Take Screenshot.

Step 9: Configure Sending Profile

Configure SMTP settings using the lab mail server provided by your instructor.

Take Screenshot.

Step 10: Create Campaign

Navigate

Campaigns

Click

New Campaign

Select

- User Group
- Email Template
- Landing Page
- Sending Profile

Launch Campaign.

Take Screenshot.

Step 11: Monitor Campaign

GoPhish Dashboard displays

- Emails Sent
- Delivered
- Opened
- Clicked

Take Screenshot.

Sample Results

Metric	Value
Total Emails Sent	20
Successfully Delivered	19
Delivery Rate	95%
Emails Opened	16
Open Rate	80%
Link Clicks	6
Click Rate	30%

(Replace these with your actual lab results.)

Observations

- Most employees received the phishing email successfully.
- A high percentage opened the email.
- Some users clicked the phishing link, indicating a need for additional awareness training.
- The simulation demonstrates how realistic phishing emails can influence user behavior.

Recommendations

1. Conduct regular phishing awareness training.
2. Encourage employees to verify sender email addresses before responding.
3. Enable Multi-Factor Authentication (MFA) for all accounts.
4. Deploy email security controls such as SPF, DKIM, and DMARC.

5. Implement advanced email filtering to detect phishing attempts.
6. Encourage users to report suspicious emails immediately.
7. Perform periodic phishing simulations to measure awareness improvements.
8. Keep operating systems and email clients updated with the latest security patches.

3. Using Nmap Aggressive Scan (-A) on scanme.nmap.org, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.

Aim

To perform an Nmap Aggressive Scan (-A) on the authorized test host **scanme.nmap.org** to identify operating system details, open ports, service versions, and other publicly available information. The results are analyzed to understand how publicly exposed information could contribute to social engineering risks and how organizations can reduce those risks.

Objective

- Perform an Nmap Aggressive Scan.
 - Identify open ports and running services.
 - Detect service versions and operating system information.
 - Analyze the security implications of the findings.
 - Recommend defensive measures to reduce information disclosure and social engineering risk.
-

Tools Required

- Kali Linux
 - Nmap
 - Internet Connection
-

Command Executed

```
nmap -A scanme.nmap.org
```

Procedure

Step 1

Open the Kali Linux Terminal.

Step 2

Verify that Nmap is installed.

```
nmap --version
```

Step 3

Run the Aggressive Scan.

```
nmap -A scanme.nmap.org
```

Step 4

Wait for the scan to complete.

Step 5

Record the discovered information, including:

- Host status
- IP Address
- Open Ports
- Running Services
- Service Versions
- Operating System Information
- Network Distance
- Traceroute (if displayed)

Take screenshots of the scan output.

Sample Output

```
Session Actions Edit View Help
(priya@priya) [~]
$ nmap -A scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 14:51 +0530
Stats: 0:02:20 elapsed; 0 hosts completed (1 up), 1 undergoing Traceroute
Traceroute Timing: About 32.26% done; ETC: 14:53 (0:00:00 remaining)
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.42s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2
f
Not shown: 978 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
1/tcp     closed tcpmux
22/tcp    open  tcpwrapped
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
53/tcp    closed domain
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
83/tcp    closed mit-ml-dev
139/tcp   closed netbios-ssn
143/tcp   closed imap
161/tcp   closed snmp
443/tcp   closed https
515/tcp   closed printer
1524/tcp  closed ingreslock
3128/tcp  closed squid-http
3389/tcp  closed ms-wbt-server
4444/tcp  closed krb524
5002/tcp  closed rfe
5060/tcp  open  sip?
5061/tcp  open  sip-tls?
7001/tcp  closed afs3-callback
8080/tcp  closed http-proxy
8081/tcp  closed blackice-icecap
8085/tcp  closed unknown
8089/tcp  closed unknown
OS fingerprint not ideal because: Didn't receive UDP response. Please try again
```

Findings

Parameter	Observation
Target	scanme.nmap.org
Host Status	Host is Up
Operating System	Linux (estimated)
Open Port	22 (SSH)
Open Port	80 (HTTP)
Open Port	9929
Open Port	31337
Service Detection	Enabled
OS Detection	Enabled
Version Detection	Enabled
(Replace with your actual scan results.)	

Security Analysis

The scan identified publicly accessible services and estimated operating system information. From a defensive perspective, this information highlights what is externally visible about a system. If an attacker collected similar publicly exposed details, they could use them to make fraudulent communications appear more credible—for example, by referencing technologies that the IT team is known to use. Such information can increase the effectiveness of phishing or impersonation attempts against support staff, even without exploiting any technical vulnerability.

Defensive Recommendations

1. Keep operating systems and software updated with the latest security patches.
 2. Disable or restrict unnecessary network services.
 3. Limit information disclosed through service banners where appropriate.
 4. Configure firewalls to expose only required services.
 5. Train IT support staff to verify requests through established procedures.
 6. Enable Multi-Factor Authentication (MFA) for administrative accounts.
 7. Monitor logs and network traffic for suspicious activity.
 8. Perform regular vulnerability assessments and security audits.
-

Result

The Nmap Aggressive Scan successfully identified publicly visible services and estimated operating system information on the authorized test host **scanme.nmap.org**. The assessment demonstrates the importance of minimizing unnecessary information exposure, maintaining secure configurations, and combining technical controls with user awareness to reduce the risk of social engineering.

Screenshots to Include

1. Kali Linux Terminal.
2. nmap --version output.
3. Running nmap -A scanme.nmap.org.
4. Complete scan results showing ports and services.
5. Final section of the output with OS detection (if available).